

AI Governance, Responsible AI & Security

54 essential terms, explained in plain language with a practical, real-world example for each — built for delivery teams, developers, data scientists, managers, risk and security professionals.

10

AI Governance

13

Responsible AI

12

Risk & Compliance

19

AI Security

AI GOVERNANCE

Who decides, owns, approves and monitors AI?

RESPONSIBLE AI

Is the AI trustworthy and respectful of people?

RISK & COMPLIANCE

What can go wrong, and what obligations apply?

AI SECURITY

How can the AI, data, model or tools be attacked or misused?

Contents & How to Use This Guide

This guide organizes 54 terms into four connected domains. Each entry pairs a plain-language definition with a practical example so a concept can be introduced and immediately grounded in a real scenario.

10 TERMS

AI Governance — Direction, ownership and oversight

AI Governance · AI Policy · AI Principles · AI Oversight Committee · AI Inventory · AI Use Case Classification · Roles and Responsibilities · Human Oversight · AI Lifecycle Management · Third-Party AI Governance

13 TERMS

Responsible AI — Fairness, transparency and trust

Responsible AI · Fairness · Bias · Transparency · Explainability · Accountability · Privacy · Safety · Reliability · Robustness · Inclusiveness · Contestability · Traceability

12 TERMS

Risk & Compliance — Assessment, validation and evidence

AI Risk Management · Risk Assessment · Risk Appetite · Risk Mitigation · Residual Risk · Compliance · AI Impact Assessment · Model Validation · Model Drift · Data Drift · Audit Trail · Documentation

19 TERMS

AI Security — Protection, access and monitoring

AI Security · Prompt Injection · Jailbreaking · Data Leakage · Sensitive Data Exposure · Model Theft · Model Poisoning · Adversarial Attack · Access Control · Least Privilege · Authentication · Authorization · Encryption · Secrets Management · AI Guardrails · Input Validation · Output Validation · Security Monitoring · Incident Response

FACILITATION TIP

Introduce each term with its definition, then walk through the example and ask participants to relate it to a system or project from their own organization. For a quick check of understanding, use the recap activity on the closing pages: ask learners to sort a new example into governance, responsible AI, risk/compliance or security.

01

AI Governance

Direction, ownership and oversight

10 TERMS IN THIS SECTION

"Who decides, owns, approves and monitors AI?"

AI GOVERNANCE

1 AI Governance

The framework of policies, roles, processes and controls an organization uses to direct how AI systems are designed, approved, deployed, monitored and eventually retired.

EXAMPLE A bank establishes an AI governance board that must approve any high-risk AI system before it reaches customers.

2 AI Policy

A formal, enforceable statement of what AI may and may not be used for, and which approvals, controls or reviews are required before use.

EXAMPLE Company policy prohibits staff from entering confidential customer data into public AI tools.

3 AI Principles

The high-level values — such as fairness, transparency, safety, privacy and accountability — that an organization commits its AI systems to uphold.

EXAMPLE An organization publishes principles requiring every customer-facing AI system to be explainable and reviewed for bias before launch.

4 AI Oversight Committee

A cross-functional body — typically spanning business, legal, risk, security and data science — that reviews significant AI initiatives before approval.

EXAMPLE Before an automated loan-decision model goes live, representatives from risk, legal, data science and security review it together.

AI GOVERNANCE

5 AI Inventory

A centralized, maintained register of every AI system in use or under development, capturing its owner, purpose, data sources, model type and risk level.

EXAMPLE The organization logs every chatbot, recommendation engine and predictive model in a central inventory for tracking and audit purposes.

6 AI Use Case Classification

A structured method for grouping AI applications by purpose, impact and sensitivity, so that proportionate controls can be applied to each.

EXAMPLE A marketing copy generator is classified as low risk, while a credit-approval system is classified as high risk and subject to stricter review.

7 Roles and Responsibilities

Clearly assigned ownership across the AI lifecycle, defining who builds, approves, operates, monitors, audits and is ultimately accountable for a system.

EXAMPLE Data science builds the model, security tests it, the business unit owns the outcome, and risk provides independent review.

8 Human Oversight

Meaningful human supervision of AI-driven decisions, particularly in situations where errors could materially affect people or the organization.

EXAMPLE An AI system flags a suspicious insurance claim, but a human investigator reviews the evidence before any claim is rejected.

AI GOVERNANCE

9 AI Lifecycle Management

The end-to-end governance of an AI system, from ideation and data collection through development, validation, deployment, monitoring, change and retirement.

EXAMPLE A model is revalidated after a major data change and formally retired once a replacement system is introduced.

10 Third-Party AI Governance

The controls applied to AI models, datasets and services sourced from external vendors, ensuring vendor risk is managed as rigorously as internal risk.

EXAMPLE Before adopting a vendor LLM, the company reviews its security practices, data retention terms, known limitations and contractual liabilities.

02

Responsible AI

Fairness, transparency and trust

13 TERMS IN THIS SECTION

"Is the AI trustworthy and respectful of people?"

RESPONSIBLE AI

11 Responsible AI

The practice of developing and deploying AI in a manner that is lawful, safe, ethical, reliable and consistent with human values and organizational obligations.

EXAMPLE A healthcare chatbot is built with privacy safeguards, medical safety disclaimers, human escalation paths and ongoing monitoring.

12 Fairness

The objective of preventing an AI system from producing unjust or systematically different outcomes for individuals or groups.

EXAMPLE A hiring model is tested to confirm that equally qualified candidates are not disadvantaged on the basis of gender or age.

13 Bias

A systematic skew in data, model behavior or process design that produces distorted or unfair outcomes, often without deliberate intent.

EXAMPLE A model trained on historical hiring data that reflects past discrimination is likely to reproduce that same pattern.

14 Transparency

Providing people with meaningful, accessible information about an AI system's purpose, data use, limitations and role in a decision.

EXAMPLE A company website clearly discloses that visitors are interacting with an AI chatbot and explains how their conversation data is used.

RESPONSIBLE AI

15 Explainability

The capacity to give an understandable, human-readable reason for why an AI system produced a specific output or decision.

EXAMPLE A credit-scoring model reports that high outstanding debt and repeated late payments were the leading factors behind a risk score.

16 Accountability

Ensuring that identifiable people or teams remain answerable for an AI system's outcomes — the model itself cannot be the fallback explanation for a failure.

EXAMPLE When an AI system incorrectly rejects a customer application, the business owner is responsible for investigating and correcting the process.

17 Privacy

Ensuring personal information used by an AI system is collected, processed, stored and shared in a manner that respects individual rights and applicable law.

EXAMPLE A chatbot strips personal identifiers from conversation logs before they are used to improve the model.

18 Safety

Reducing the likelihood that an AI system causes physical, financial, psychological, operational or societal harm.

EXAMPLE An industrial AI system automatically halts a recommendation when sensor readings indicate an unsafe operating condition.

RESPONSIBLE AI

19 Reliability

The consistency with which an AI system performs correctly and predictably under the conditions it was designed for.

EXAMPLE A document classifier is tested across different file formats and business units to confirm stable, repeatable performance.

20 Robustness

An AI system's ability to keep functioning properly when it encounters noisy, unusual, incomplete or deliberately manipulated inputs.

EXAMPLE An image-recognition model continues to perform reliably on photos that are slightly blurred or compressed, rather than failing outright.

21 Inclusiveness

Designing AI systems with awareness of the different users, abilities, languages and social contexts they will encounter.

EXAMPLE A voice assistant is tested against a range of accents and offers a text-based alternative for users who cannot use speech.

22 Contestability

Giving people a defined route to question, appeal or request human review of a decision made or influenced by AI.

EXAMPLE A customer denied a loan can request a manual review and submit additional supporting information.

RESPONSIBLE AI

23 Traceability

The ability to reconstruct the events, data, model version, prompts, approvals and decisions behind an AI system's behavior.

EXAMPLE Audit logs show exactly which model version, prompt template and data source produced a specific chatbot response.

03

Risk & Compliance

Assessment, validation and evidence

12 TERMS IN THIS SECTION

"What can go wrong, and what obligations apply?"

RISK & COMPLIANCE

24 AI Risk Management

A structured, repeatable approach to identifying, assessing, treating, monitoring and reporting the risks an AI system introduces.

EXAMPLE Before deployment, a company scores an AI use case for privacy, security, bias, legal and operational risk.

25 Risk Assessment

The structured process of estimating both the likelihood and the potential impact of an AI system's possible failures or harms.

EXAMPLE A healthcare AI is rated high-impact because an incorrect recommendation could directly affect patient treatment.

26 Risk Appetite

The level and type of AI-related risk an organization is willing to accept in pursuit of its business objectives.

EXAMPLE A bank may tolerate moderate risk for an internal summarization tool but requires very low risk for automated credit decisions.

27 Risk Mitigation

The specific actions taken to reduce either the probability or the impact of an identified AI risk.

EXAMPLE To reduce hallucination risk, a chatbot is restricted to approved knowledge sources and paired with response validation and human escalation.

RISK & COMPLIANCE

28 Residual Risk

The risk that remains after all reasonable controls and mitigations have already been applied.

EXAMPLE Even with rigorous testing and guardrails in place, a generative AI assistant may still occasionally produce an incorrect answer.

29 Compliance

Meeting the laws, regulations, industry standards, contractual obligations and internal policies that apply to an AI system.

EXAMPLE The company documents its data-processing practices and access controls to satisfy privacy and industry regulations.

30 AI Impact Assessment

A structured, documented review of how an AI system may affect people's rights, safety, privacy, operations or society at large.

EXAMPLE Before deploying facial recognition, the organization evaluates necessity, privacy impact, potential bias, misuse risk and viable alternatives.

31 Model Validation

Independent, structured testing to confirm that a model performs within acceptable limits and is fit for its intended use before it is approved.

EXAMPLE A risk team independently tests a fraud-detection model against unseen data before granting production approval.

RISK & COMPLIANCE

32 Model Drift

A decline or shift in a model's accuracy or behavior over time, caused by real-world conditions or relationships changing since training.

EXAMPLE A demand-forecasting model becomes noticeably less accurate after a significant shift in customer buying behavior.

33 Data Drift

A change in the statistical properties of a model's live input data compared with the data it was originally trained or validated on.

EXAMPLE A fraud model trained mainly on card payments experiences data drift as mobile-wallet transactions become the dominant channel.

34 Audit Trail

A chronological record of significant activities and decisions that allows a reviewer to reconstruct what happened and who was responsible.

EXAMPLE The system logs every model approval, deployment date, configuration change and administrator action.

35 Documentation

Maintained, accessible records covering a system's data, design, intended use, known limitations, testing and ownership.

EXAMPLE A model card sets out what a model does, where it should not be used, and its known performance limitations.

04

AI Security

Protection, access and monitoring

19 TERMS IN THIS SECTION

"How can the AI, data, model or tools be attacked or misused?"

AI SECURITY

36 AI Security

The discipline of protecting AI systems, models, data, infrastructure and users from unauthorized access, manipulation, misuse, leakage and attack.

EXAMPLE An enterprise LLM deployment is protected with identity controls, encryption, prompt filtering, monitoring and network restrictions.

37 Prompt Injection

An attack in which malicious instructions — embedded in a prompt or in external content the AI reads — attempt to override its intended behavior.

EXAMPLE A webpage contains hidden text instructing an AI assistant to ignore company rules and disclose confidential information.

38 Jailbreaking

Attempts to bypass an AI model's built-in safety rules or usage restrictions through specially crafted or persistent prompts.

EXAMPLE A user repeatedly rephrases a prohibited request in different ways to trick the model into disabling its own safety controls.

39 Data Leakage

The unintended exposure of confidential, sensitive or personal information through the use of an AI system.

EXAMPLE An employee pastes a confidential contract into a public chatbot, and the content is retained outside approved company systems.

AI SECURITY

40 Sensitive Data Exposure

A security failure in which protected information — such as passwords, personal identifiers, medical records or financial data — becomes visible to unauthorized users.

EXAMPLE A generated customer-support reply accidentally includes another customer's account number.

41 Model Theft

The unauthorized copying, extraction or replication of a proprietary model's parameters or behavior.

EXAMPLE An attacker submits thousands of carefully chosen queries to reverse-engineer and approximate the behavior of a commercial model.

42 Model Poisoning

The deliberate manipulation of training or fine-tuning data so that a model learns harmful, biased or attacker-controlled behavior.

EXAMPLE An attacker inserts malicious examples into a training dataset so that a spam filter begins allowing specific harmful messages through.

43 Adversarial Attack

Input that is deliberately crafted to cause an AI model to make an incorrect prediction or behave in an unintended way.

EXAMPLE Small, carefully calculated changes to an image cause a vision model to misclassify a stop sign.

AI SECURITY

44 Access Control

The mechanisms that restrict AI systems and their underlying resources so that users and services can access only what they are authorized to use.

EXAMPLE Only approved HR staff are permitted to use an AI assistant that is connected to employee records.

45 Least Privilege

The principle of granting users, applications and AI agents only the minimum level of access required to complete their task, and no more.

EXAMPLE A customer-support agent can read order status but cannot access payroll data or modify financial records.

46 Authentication

The process of verifying that a user or system is who it claims to be before granting access to AI services or data.

EXAMPLE Employees must sign in with multi-factor authentication before they can use the internal AI platform.

47 Authorization

The process of determining what an already-authenticated user or system is permitted to do.

EXAMPLE A manager can view team-wide analytics, while an individual employee can only view their own information.

AI SECURITY

48 Encryption

Transforming data into a form that unauthorized parties cannot read without the correct cryptographic key.

EXAMPLE Customer prompts are encrypted both while moving across the network and while stored in the database.

49 Secrets Management

The secure storage, rotation and controlled distribution of credentials such as API keys, tokens, passwords and certificates.

EXAMPLE An API key is stored in a secure secrets vault rather than being hard-coded into a Python notebook.

50 AI Guardrails

Technical and procedural controls that constrain unsafe inputs, outputs, tool actions or data access within an AI system.

EXAMPLE A chatbot blocks requests containing account passwords and refuses to execute high-risk database commands.

51 Input Validation

Checking and sanitizing information entering an AI system to confirm it is expected, safe and properly formatted before it is processed.

EXAMPLE The system rejects file uploads that exceed a size limit or contain unsupported executable content.

AI SECURITY

52 Output Validation

Checking AI-generated results before they are displayed, stored or used to trigger a downstream action.

EXAMPLE Before a generated SQL query is executed, a validator confirms it contains only read-only operations.

53 Security Monitoring

The continuous observation of AI activity, logs, alerts and behavior patterns to detect suspicious or abnormal events.

EXAMPLE Security monitoring flags a single user sending thousands of unusual prompts designed to extract protected information.

54 Incident Response

The defined process for detecting, containing, investigating, recovering from and learning after an AI-related security or safety incident.

EXAMPLE After a chatbot exposes restricted data, the organization disables access, investigates the logs, notifies stakeholders and closes the control gap.

How the Four Areas Connect

Each domain answers a different question about the same AI system — together they form a complete picture of trustworthy AI.

AREA	MAIN QUESTION	TYPICAL CONTROLS
AI Governance	Who decides, owns, approves and monitors AI?	Policies, inventory, oversight, roles, lifecycle gates
Responsible AI	Is the AI trustworthy and respectful of people?	Fairness testing, transparency, explainability, human oversight
Risk & Compliance	What can go wrong, and what obligations apply?	Risk assessments, validation, documentation, audit evidence
AI Security	How can the AI, data, model or tools be attacked or misused?	Access control, encryption, guardrails, monitoring, incident response

END-TO-END EXAMPLE

Consider an AI chatbot deployed by a bank. Governance decides who owns the system and what it is permitted to do. Responsible AI ensures customers are treated fairly and know they are speaking with an AI. Risk and compliance teams evaluate privacy, regulatory, operational and model risk. Security protects the prompts, customer data, APIs, identities and connected tools. All four domains work together to make the system trustworthy.

10 Questions to Ask About Any AI System

Use this checklist to open a discussion, structure an AI review, or close out a training session.

- 1 What is the business purpose of the AI system?

- 2 Who owns it, and who is accountable for its outcomes?

- 3 What data does it use, and is that data appropriate?

- 4 Could the AI produce unfair outcomes for any group?

- 5 Can users understand the AI decisions that affect them?

- 6 Is meaningful human review available when it matters?

- 7 What are the primary security threats to this system?

- 8 How is sensitive data protected throughout its lifecycle?

- 9 How will performance, drift, incidents and misuse be monitored?

- 10 What evidence will be retained for audit and compliance?

54 terms. Four domains. One shared goal — trustworthy AI.

Governance sets direction. Responsible AI protects people. Risk & compliance provide evidence and control. Security defends the system itself. Used together, they turn AI from a source of uncertainty into a well-managed capability.

AI Governance, Responsible AI & Security — Simple Terms Guide